

File No.: EXP202207523

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on June 27, 2022. The complaint is directed against the GENERAL DIRECTORATE OF THE CATASTRO with NIF S2826053G (hereinafter, the CATASTRO). The reasons for the complaint are as follows:

The complainant states that on the official website of the electronic headquarters of the CATASTRO, in the section -generate certifications-, when entering any DNI, fields were auto-filled with the person's name, surname, and address, all without the need to register on the electronic headquarters. These facts were made available to the competent administration (General Directorate of the Catastro) on June 26, 2022, and at the time of filing this complaint, the incident persisted. Furthermore, the complainant has indications that this situation has been occurring for more than 6 months. He claims that the URL of the form was accessible through the Google search engine.

On July 17, 2022, this Agency received a new document from the complainant providing a screenshot taken with a mobile phone showing a form linked to the electronic headquarters of the catastro and an example of a query made for a DNI number, with the name and surname fields filled in. The screenshot was taken on June 28, 2022, and is provided as evidence of the facts reported in the complaint submitted by this same party on June 27, 2022.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the CATASTRO for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was accepted on July 12, 2022, as recorded in the certification in the file.

On July 29, 2022, this Agency received a response letter indicating that "1. Detailed and chronological description of the events that occurred.

On June 26, an incident was received in the electronic headquarters mailbox notifying a possible vulnerability in the section -generate certifications- of the electronic headquarters of the catastro. Following the incident, the referred section was reviewed, and no anomaly was found, so more information was requested from the user. On the 28th, the user was asked about the steps taken in the referred access, and the user responded that same day detailing them.

At that moment, an investigation into the behavior was initiated, and a first correction was made, eliminating direct access to the problematic page on July 1. This was subsequently communicated to the sender of the incident on July 6.

2. Detailed specification of the causes that made the incident possible.

One of the options offered in the electronic headquarters is the generation of certifications with a cadastral accreditation fee. This service is only accessible to registered users, whose identification is carried out on the registered access page and is verified on each and every page. This specific page has an option to auto-fill the name and surname fields when the applicant's NIF is entered, to facilitate the completion of the form by the registered user.

The incident occurred because in the Google search engine, when searching for "generation certifications catastro," the third link that appeared was a direct URL to the following page:

***URL.1

When accessing that link, although no protected data was displayed (as it was checked whether the user had permission to view it), the empty form was visible, and if a valid NIF was entered in the NIF field, that part of the page refreshed, showing the name and surname associated with that NIF.

This was not detected in previous tests because the verification consisted of ensuring that no data was

displayed to users who were not authorized, but it was not checked that the fields of the form were not filled in either.

3. Number of people affected by the violation of personal data security.

The function of auto-filling the name and surname from the NIF is offered after prior authentication and does not generate a request to the system.

Since no protected data stored in the Catastro (ownership of properties or their cadastral value) was offered, there is no record in the database of such accesses.

To estimate the scope of the problem with that limitation, the queries made since the implementation of this functionality (year 2016) were reviewed in the accessed tables, and 575 queries were found for which there is no record of prior authentication. This is not a high number for that period.

4. Category of personal data involved.

In this regard, it should be noted that after entering the NIF, the name and surname fields are auto-filled, but no specific protected data from the Catastro (ownership of properties or their cadastral value) is provided.

5. Possible consequences for the affected individuals.

3/22

If someone managed to access in this way and entered a valid complete NIF, they could obtain the corresponding name and surname associated with that NIF. However, the possible uses of this information are unknown.

6. Detailed description of the actions taken to resolve the incident and minimize its impact on the affected individuals.

As soon as the problem was detected, direct access to that page was removed.

To correct it, it is now verified that if the user does not have permission to view the data, the form is also not displayed, indicating that their session has expired, thus forcing them to authenticate. This page is only authorized for viewing by registered users with the appropriate authorization; if the user is not of this type, the form will not be displayed.

On the other hand, the metadata provided by Google has also been added to all pages of the Electronic Headquarters of the Cadastre to identify the General Directorate of the Cadastre as the owner, allowing us to request that they clear from the cache and remove from the search results any page we indicate.

For this specific case, metadata has also been added so that it is not indexed by the search engine and never appears as a search result.

7. Security measures for the processing of personal data adopted prior to the incident, as well as the supporting documentation of the Risk Analysis that led to the implementation of such security measures and, where applicable, a copy of the Impact Assessments of the processing where the personal data security breach occurred.

The updated security measures for the processing of personal data are reported in the compliance status of the National Security Scheme of the General Directorate of the Cadastre according to the CCN-STIC-824 guide, included in the INES tool, section 3.7 Information Protection, subsection 1. Personal data.

In any case, the latest complete Statement of Applicability from March 2021 is attached, which reflects matters related to the processing of personal data in the confidentiality dimension (C).

8. Copy of the Activity Register of the processing where the incident occurred.

In general, the processing of the Electronic Headquarters of the Cadastre, excluding mass downloads of information, falls under activity E00127105-002 of the Activity Register (RAT). The aforementioned RAT file from the General Directorate of the Cadastre is attached.

9. If the security breach has been communicated to the affected individuals, indicate the channel used, date of communication, and details of the message sent. If not, indicate the reasons.

As a consequence of the low number of possible affected individuals since 2016 (575 data queries without prior authentication, which would rule out a mass consultation action by any automated means), combined with the category of personal data involved (name and surname after entering a valid ID registered in the Cadastre Database), it does not confer a sufficient level of impact on the affected individuals for it to constitute a probable risk to their rights and freedoms, so it would not fall

under the assumption of Article 34 of the GDPR, to notify the affected individuals of such a breach.

10. Indicate whether the security breach has been reported to this Supervisory Authority. If not, indicate the reasons why the security breach has not been reported.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/22

notified to this Control Authority within 72 hours from the moment it has been acknowledged. You can obtain information on the management and notification of security breaches at the following link from the Agency: ***URL.2

As responded in the previous section, the low number of potential affected individuals since 2016 (575 data inquiries without prior authentication, which would rule out a massive inquiry by any automated means), combined with the category of personal data involved (name and surname prior to the introduction of a valid ID registered in the Land Registry Database), does not confer sufficient impact on the affected individuals for the security breach to constitute a probable risk to their rights and freedoms, thus not falling under the provisions of Article 33 of the GDPR for notifying this breach to that Agency.

11. Measures you intend to adopt to prevent a similar incident from occurring in the future.

For all pages that require prior authentication, the following functionality has been implemented: it is checked that if the user does not have permissions to view the data, the requested page is not displayed, informing them that their session has expired, thus forcing them to authenticate.

On the other hand, metadata provided by Google has also been added to all our pages to request the deletion of any of our URLs from the search engine's cache that we ask for...

THIRD: On August 18, 2022, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing.

On August 18, 2022, a new document was received by this Agency from the complainant, with entry registration number REGAGE22e00035737498, in which it is stated that in the admission agreement it was indicated by this Agency that the auto-filled data in the form were name and surname linked to the entered NIF; however, it claims that this Agency had overlooked the most burdensome element presented in the original complaint, which was the address field also auto-filled in the form.

FOURTH: The General Sub-Directorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On July 29, 2022, and with entry registration number REGAGE22e00032983383, a written response to the transfer of the complaint made by this Agency was received. From its analysis, the following is extracted:

1. They state that on June 26, 2022, they received the incident in the electronic headquarters mailbox notifying of said vulnerability, that more information was requested from the user on June 28, 2022, with the user responding to the request on the same day. At that moment, an investigation into the facts was initiated, and a first correction was made, eliminating direct access to the page.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/22

issue on July 1, 2022. Subsequently, the sender was informed on July 6, 2022.

2.

Regarding the causes that led to the incident, they state that it occurred because the form was

exposed on the internet accessible from the Google search engine, and that when the NIF field was filled with a valid data, the fields for name and surname corresponding to the entered NIF were refreshed. This anomaly was not detected in the prior tests that had been conducted because the verification consisted of ensuring that no cadastral data was displayed to users who were not authorized, but it was not checked that the fields of the form were also not filled out.

3.

Regarding the affected individuals, they state that after reviewing the internal logs, 575 queries have been detected since the form was activated in 2016.

4.

Regarding the categories of affected data, they state that only the name and surname fields were auto-filled.

5.

Regarding the actions taken to resolve the incident, they state that to correct it, the user has been forced to be authenticated in order to display the form, and that this form is only shown to authorized registered users.

6.

Regarding our request for existing measures, Risk Analysis, and Impact Assessment, they state that the list of implemented measures is as specified in the National Security Scheme (ENS), providing a document with the Declaration of Applicability dated March 2021 (this is the document that includes the selected and implemented measures from those specified in Annex II of the ENS). They do not provide either a Risk Analysis or an Impact Assessment.

7.

They provide the Record of Processing Activities (RAT).

8.

Regarding the communication of the breach to the affected individuals and the notification to this Agency, they state that considering the low number of possible affected individuals (575) and that it only affected the types of data name and surname, it does not pose a risk to the rights and freedoms of the affected individuals, and therefore, notification to this Agency and communication to the affected individuals is not warranted. However, during the course of this investigation, the AEPD tool "Asesora BRECHA" was used, yielding the following result: "THE CONTROLLER MUST NOTIFY THE AEPD OF THE PERSONAL DATA BREACH WITHOUT UNDUE DELAY," a conclusion obtained using the following input data:

- The incident has affected confidentiality.
- The incident occurred due to a failure, absence, or breach of security measures.
- There is a likelihood that the breach poses some risk to the rights and freedoms of individuals, as there has been a loss of control over the personal data of the affected individuals in the 575 detected queries.

On the other hand, regarding the obligation to communicate the breach to the affected individuals, the AEPD tool "Comunica-Brecha RGPD" was used during this investigation, yielding the result: "IT WOULD NOT BE NECESSARY TO COMMUNICATE THE SECURITY BREACH TO THE AFFECTED INDIVIDUALS," based on the following input data:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/22

o

Individuals will not be affected or may encounter only very limited and reversible inconveniences that they will overcome without any problem.

o

There is no evidence of actual damages, and the likelihood of occurrence is low.

o

The affected data includes name, surname, and postal address.

o

Approximately 575 individuals have been affected.

1.

They state that as a measure implemented to prevent the incident from recurring, it has been enforced that the user must be authenticated at the headquarters and have the appropriate permissions to access this form.

On September 21, 2022, a request for information was made to the General Directorate of the Cadastre, marked by the following lines of inquiry:

- Obtain information on the type of authenticated user at the headquarters who would have access to the form once the corrective measures are implemented.
- Obtain confirmation on whether the address field was also auto-filled when entering the NIF field and therefore was also a personal data leaked in the security breach.
- Request the Risk Analyses for the processing activity "Cadastre Database – SIGECA."
- Regarding the ENS:

- o Obtain information about the level of security dimension of the information systems that support the previous processing activity.

- o Obtain clarification on why the authentication mechanism in the electronic headquarters based on "NIF Number + DNI Support Number + Cadastral Reference of the Holder" is used instead of the digital certificate (the more secure authentication method recommended by the ENS in security measures).

- o Obtain a copy of the last mandatory ENS audit conducted according to the ENS itself.

On October 5, 2022, with entry registration numbers REGAGE22e00044314252 and REGAGE22e00044314408, a response to the previous information request was received. From the analysis of this response, the following is concluded:

1.

They state that the form is accessible exclusively to registered users at the headquarters of the "Management" type so that an authorized official can obtain the cadastral certification requested by the citizen through this form. They affirm that the auto-fill function remains active to facilitate functionality.

2.

They confirm that the address of the person for whom the NIF was entered was also auto-filled.

3.

Regarding the requested Risk Analysis, only one document is provided, which was obtained using the "Evaluate Risk RGPD" tool from the AEPD. From the analysis of this document, it is concluded:

a.

The document is dated October 5, 2022, at 13:48 hours.

b.

It indicates a High Intrinsic Risk assessment and a Low Residual Risk assessment.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/22

c. At the bottom of the document, the following text is included by the tool: "This report serves as a supporting document for risk management and does not, under any circumstances, replace or substitute the obligations of those responsible and those in charge."

4. Regarding the information requested about compliance with the ENS:

a. They state that the category of the Cadastre Information System (SIC) that serves as the basis for the data processing affected by the security breach is classified as MEDIUM LEVEL.

b. They assert that the existing authentication mechanism in the electronic headquarters based on knowledge of the data: (...) (a less secure authentication option than the electronic certificate recommended by the ENS) was implemented following Order HFP/1423/2021 of December 20, which modified Order EHA/2219/2010 of July 29, which approves the electronic signature system with a

shared key for actions in the associated electronic headquarters of the General Directorate of the Cadastre. They claim that this order was approved with the intention of providing the greatest possible facilities under Royal Decree 463/2020 of March 14, which declared a state of alarm for managing the health crisis situation caused by COVID-19.

c. They provide a document with a compliance report for the ENS prepared by the company "GMV Soluciones Globales Internet S.A.U" in December 2017. This document summarizes the actions to be taken to achieve the objectives set by the General Directorate of the Cadastre according to the Security Guide CCN-STIC-806 (Compliance with the National Security Framework).

FIFTH: On May 5, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party for the alleged infringement of Article 5.1.f) of the GDPR classified under Article 83.5 of the GDPR, for the alleged infringement of Article 32 of the GDPR and Article 33 of the GDPR classified under Article 83.4 of the GDPR.

SIXTH: After notifying the aforementioned initiation agreement in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the accused party submitted a written statement of allegations in which they stated:

FIRST. - Regarding their statement on page 11 of the aforementioned document: "The exposure on the public internet of a form that should only be accessed after user identification in the electronic headquarters does not meet the minimum reasonable security measures. This form allowed for the automatic completion of the fields for name, surname, and address of the person referred to by this NIF when the NIF field was filled with a valid value. Consequently, the exposure of this form does not guarantee the confidentiality, integrity, and availability of the processing systems and services nor the purpose of the processing." In this regard, it is considered that the incident may have affected only the confidentiality in a very residual manner, as it provided a...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/22

information that should not have been offered (name, surname, and address of the person to whom the NIF corresponded).

However, in no case did it affect integrity because the existing data in the Cadastre was not altered as it was a Consultation function. Nor did it affect availability, as the service of the Electronic Headquarters of the Cadastre was not interrupted temporarily or permanently by the incident, as can be inferred from the provisions on pages 9 and 13 of your document.

"SECOND.- Regarding your statement on page 13 of the aforementioned document:

"In this case, the CADASTRE did not notify the security breach within the timeframe established in the GDPR for this purpose, with the information established in Article 33 of the GDPR; since it considered that there was no risk to the rights and freedoms of the affected individuals, taking into account the volume of data leaked (575 queries), the type of data (name, surname, and address), and the time the form has been in production (since 2016)."

Firstly, having conducted the risk assessment through the Asesora-Breach tool of the Spanish Data Protection Agency, the result obtained, related to a security breach in the processing of personal data in which the confidentiality of the data has been compromised and the possible risks of such loss of confidentiality have been mitigated, without affecting the integrity and availability of the data, was that "it is not necessary to notify the personal data breach to the AEPD."

An image of the result obtained is attached:

Furthermore, once this Management Center became aware of the security breach, measures were immediately implemented to remedy it, thus mitigating the possible risks of loss of confidentiality.

Direct access to the webpage where the incident occurred was also removed, through the Google search engine "generation certifications cadastre." Additionally, to correct it, it was verified that if the user did not have permissions to view the data, the form was also not displayed, indicating that their session had expired, thus forcing them to authenticate. Moreover, this page is only authorized for

viewing by registered users with the appropriate authorization.

On the other hand, metadata provided by Google was also added to all pages of the Electronic Headquarters of the Cadastre to identify the General Directorate of the Cadastre as the owner and thus request it to delete from the cache and remove from the search results any page indicated.

For this specific case, metadata was also added so that it would not be indexed by the search engine and would never appear as a search result.

Secondly, it should be noted that when entering the NIF, the previously existing autocomplete option, which aimed to facilitate the completion of forms for registered users, would autocomplete the fields for name, surname, and address, but did not provide any specific protected data from the Cadastre (ownership of properties, or their cadastral value).

In conclusion, a table is attached showing the volume of accesses to the Electronic Headquarters of the Cadastre by year since 2016, where it can be seen the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/22

volume of the breach (575 queries) compared to the annual volume of accesses to the headquarters, constituting 0.0000841247655% of the total.

Years

Visits to Headquarters

2016

70,005,043

2017

77,011,004

2018

78,827,767

2019

126,926,632

2020

170,807,374

2021

159,930,772

Total

683,508,592

SEVENTH: On June 9, 2023, a resolution proposal was made, in which the allegation regarding the non-obligation to notify the security breach, in accordance with Article 33 of the GDPR, was estimated, and it was proposed to impose on the GENERAL DIRECTORATE OF CATASTRO, with NIF S2826053G, a warning sanction for each of the violations for an infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

EIGHTH: Once the resolution proposal was notified, on December 27, 2023, a note was issued by the Director of the Spanish Agency for Data Protection; in which, following the criteria of this agency regarding such cases, it considers that the following infringements occur in the present sanctioning file, processed against the GENERAL DIRECTORATE OF CATASTRO, to which the following sanctions correspond:

- Warning sanction for the infringement of Article 5.1.f) of the GDPR classified under Article 83.5 of the GDPR.

- Warning sanction for the infringement of Article 32 of the GDPR classified under Article 83.4 of the GDPR.

- Warning sanction for the infringement of Article 33 of the GDPR classified under Article 83.4 of the GDPR.

NINTH: In accordance with Article 90.2 of Law 39/2015, of October 1, on the Common Administrative

Procedure of Public Administrations, the GENERAL DIRECTORATE OF CATASTRO was notified of said note on December 28, 2023, so that within 15 days they could allege whatever they deemed appropriate in their defense against the infringement of Article 32 of the GDPR and present the documents and information they consider pertinent, in accordance with Article 89.2 of the LPACAP. TENTH: Once the aforementioned note was notified in accordance with the established rules in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and within the granted period, the summoned party has submitted a written statement of allegations considering that the warning sanction for the violation of Article 33 of the GDPR proposed is not appropriate.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/22

From the actions carried out in the present procedure and from the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is established in the file that on the official website of the electronic headquarters of the CATASTRO, in the section -generate certifications-, when entering any DNI, fields were auto-filled with the person's name, surnames, and address, all without the need to register beforehand in the electronic headquarters.

SECOND: It is established in the file that 575 queries of data have been detected for which there is no prior authentication, since the form was activated in 2016.

THIRD: It is proven in the file that the types of data affected are the name and surnames, as well as the address of the person whose NIF was entered.

FOURTH: It is established in the file that when using the Asesora-Breach tool, it was not taken into account that the risk of identity theft or impersonation poses a risk to the rights and freedoms of the affected individuals.

LEGAL GROUNDS

I

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

In relation to the imputation of Article 32 of the GDPR, the summoned entity stated the following in its written allegations to the initiation agreement:

FIRST. - Regarding its statement on page 11 of the aforementioned document: "The exposure on the public internet of a form that could only be accessed after user identification in the electronic headquarters does not comply with the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/22

minimum reasonable security measures. This form allowed for the automatic completion of the fields for name, surname, and address of the person to whom this NIF referred when a valid value was

entered in the NIF field.

Consequently, the exposure of this form does not guarantee the confidentiality, integrity, and availability of the systems and services of the processing nor the purpose of the processing.”

In this regard, it is considered that the incident may have affected, in a very residual manner, only the confidentiality, by providing information that should not have been offered (name, surname, and address of the person to whom the NIF corresponded).

However, in no case did it affect the integrity because the existing data in the Cadastre was not altered as it was a Query function. Nor did it affect availability, as the service of the Electronic Headquarters of the Cadastre was not interrupted temporarily or permanently by the incident, as can be inferred from the provisions on pages 9 and 13 of your document.

In response to this allegation, this Spanish Agency for Data Protection must remind that Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter security breach) as “all breaches of security that result in the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.”

Consequently, in the present case, there is a personal data security breach under the circumstances indicated above, categorized as a breach of confidentiality, as a form was exposed on the public internet that should only have been accessed after user identification at the electronic headquarters. However, regardless of this, when the initiation agreement refers to confidentiality, integrity, and availability, it refers to the systems and services of the processing, as well as the purpose of the processing.

Article 32 of the GDPR imposes on the controllers of personal data processing the obligation to determine and establish appropriate technical and organizational security measures to ensure a level of security appropriate to the risk, based on the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights and freedoms of individuals.

That is to say, the objective of such technical and organizational security measures must be to guarantee the confidentiality, integrity, and availability of the personal data subject to processing.

For all the above reasons, the allegation was dismissed.

Regarding the imputation of Article 33 of the GDPR, the entity being claimed refers in its written allegations to the note from the Director dated December 27, 2023, according to the order presented, as follows:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/22

In response to the allegations made regarding the Director's note by the entity being claimed against, the following is noted, according to the order presented:

“FIRST. - Regarding your statement on page 13, first paragraph of the aforementioned document:

“Having said the above, as a consequence of the security breach suffered concerning the affected individuals, the General Directorate of the Cadastre states that after reviewing the internal logs, 575 queries have been detected since the form was activated in 2016, which does not mean that more queries were not made, although they could not be detected.”

In this regard, it seems that the resolution suggests that more queries may have occurred than the 575 detected after reviewing the internal logs. At this point, this General Directorate can positively confirm that there have been no more queries than those reflected, which are the 575 that were previously reported to that Agency. The tracing tool provides information on all accesses made, and there cannot be any access that is not reflected and counted.”

In response to the allegations, this Spanish Agency for Data Protection must emphasize that 575 queries to the form is more than sufficient to pose a risk to the rights and freedoms of individuals, for the purposes of what is prescribed in Article 33 of the GDPR.

“SECOND. - Regarding your statement on page 13, second and fourth paragraphs of the

aforementioned document:

“Data regarding name, surname, and postal address was accessed, but the requester also knew the NIF of the data subjects; therefore, there was indeed a risk to the rights of individuals given that there was a risk of identity theft.”

“Moreover, depending on the situation of the data subjects, this loss of confidentiality could have generated greater risks to the rights and freedoms of individuals.”

This General Directorate understands that such a risk may have existed. However, it was initially considered to be residual. Just as in the Electronic Headquarters of the Cadastre, knowing the name and the NIF code is not sufficient to impersonate identity in procedures; this is standard practice across all digital administration and in equivalent processes in the private sector.

Furthermore, it should be reiterated, as already mentioned in previous writings, that once this Management Center became aware of the security breach, measures were immediately implemented to remedy it, thus mitigating the possible risks of loss of confidentiality. Direct access to the webpage where the incident occurred was also removed, through the Google search “generation certifications cadastre.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/22

Also, to correct it, it was verified that if the user did not have permissions to view the data, the form was not displayed either, indicating that their session had expired and thus forcing them to authenticate. Additionally, this page is only authorized for viewing by registered users with the appropriate authorization.

On the other hand, metadata provided by Google was also added to all pages of the Electronic Headquarters of the Cadastre to identify the General Directorate of the Cadastre as the owner and thus request that it delete from the cache and remove from the search results any page indicated. For this specific case, metadata was also added so that it would not be indexed by the search engine and would never appear as a search result.”

In response to this allegation, this Spanish Agency for Data Protection is pleased that the General Directorate acknowledges “... that this risk may have existed...” as well as the measures taken immediately for its remedy and correction, thus attempting to mitigate the possible risks of loss of confidentiality.

“THIRD. - Regarding your statement on page 13, fifth paragraph of the aforementioned document:

“To further elaborate, it should be noted that CATASTRO has only provided the result that it indicates it obtained from the ‘advisory-breach’ tool, but does not provide what information was entered to arrive at such a result.”

Regarding this point, it should be noted that the parameters entered in the risk assessment through the Advisory-Breach tool of that Spanish Agency for Data Protection, which yield the result according to which “it is not necessary to notify the personal data breach to the AEPD,” are those collected in Annex 1.”

In response to the allegations and regarding the parameters used in the Advisory-Breach tool, it should be mentioned that in the section related to the risk to the rights and freedoms of the affected individuals, at the time of its completion, the help section was disregarded, in which it literally states:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/22

In the present case, it is evident that data regarding name, surname, and postal address were accessed, but additionally, the requester also knew the NIF (Tax Identification Number) of the data subjects; therefore, there was indeed a risk to the rights of the individuals given that there was a risk of

identity theft or impersonation.

Consequently, the allegations presented are dismissed.

III

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it is noted that the personal data of the claimant, contained in the CATASTRO database, were improperly exposed to third parties, violating the principle of confidentiality.

According to the file, the security breach suffered by the General Directorate of the Cadastre was caused by the exposure on the public internet of a form that was only to be accessed after user identification in the electronic headquarters.

This form allowed for the automatic completion of the fields for name, surname, and address of the person to whom this NIF referred when the NIF field was filled with a valid value.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/22

The CATASTRO did not respect the principle of confidentiality, since access to this form was only granted after identification in the electronic headquarters, and it automatically filled in the fields related to the name, surname, and address of the person corresponding to that NIF when the NIF field was filled with a valid value.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringement classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include,

among others:
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/22

- a) pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, especially as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as a factor to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law. In this case, at the time of the security breach, there is no record that the CATASTRO had reasonable security measures in place based on the estimated potential risks.

The exposure on the public internet of a form that was only to be accessed after user identification in the electronic headquarters does not meet the minimum reasonable security measures. This form allowed for the automatic completion of the fields for name, surname, and address of the person to whom this NIF referred when the NIF field was filled with a valid value.

Consequently, the exposure of this form does not guarantee the confidentiality, integrity, and availability of the processing systems and services nor the purpose of the processing.

It has been established in the file that the improper exposure of the form on the internet was not detected in the system's prior tests; this was due to the fact that the tests conducted consisted of verifying that no cadastral data was displayed to unauthenticated users in the headquarters, but it was not checked that the fields of the form were not automatically filled in, evidencing that the tests conducted for the implementation of the functionality were not sufficient or adequate.

Following the knowledge of the security breach, the following measures were adopted:

- Users are required to be identified in the electronic headquarters and have "management" permissions enabled to be able to display the form.
- For all pages that have similar characteristics to the form, functionality is implemented to check that if the user attempting to access does not have adequate permissions, the page is not displayed, indicating that their session has expired and thus forcing them to authenticate with the correct permissions.
- A metadata provided by Google is added to all pages to request the deletion of the cache of the search engine for any requested URL.

VI

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a limitation period of two years: infringements that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

VII

Article 33 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/22

Article 33 "Notification of a personal data breach to the supervisory authority" of the GDPR states:

"1. In the event of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless it is unlikely that the personal data breach will result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the potential consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate the possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this Article."

In this case, the CATASTRO did not notify the security breach within the timeframe established by the GDPR for this purpose, with the information set out in Article 33 of the GDPR; as it considered that there was no risk to the rights and freedoms of the affected individuals, taking into account the volume of data leaked (575 queries), the type of data (name, surname, and address), and the time the form has been in production (since 2016).

However, during the course of this investigation, the AEPD tool "Breach Advisor" was used with the following input data, resulting in the "Obligation to notify the security breach":

- The incident has affected confidentiality.

- The incident occurred due to a failure, absence, or breach of security measures.

- There is a likelihood that the breach poses some risk to the rights and freedoms of individuals as there has been a loss of control over the personal data of the affected individuals in the 575 detected

queries.

Regarding the affected individuals, the CATASTRO states that after reviewing the internal logs, 575 queries have been detected since the form was activated in 2016. Access was made to data such as name, surname, and postal address, but the inquirer also knew the NIF of the data subjects; therefore, there was indeed a risk to the rights of individuals as there was a risk of identity theft. On the other hand, the inquirers were not logged in, so it is unknown who accessed the data, as well as the particular situation of the data subjects whose data was accessed.

Moreover, depending on the situation of the data subjects, this loss of confidentiality could have generated greater risks to the rights and freedoms of individuals.

VIII

Classification of the infringement of Article 33 of the GDPR

The aforementioned infringement of Article 33 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Serious infringements that involve a substantial violation of the articles mentioned therein shall be considered serious and shall be subject to a limitation period of two years, particularly the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/22

“(…)

r) The failure to notify the data protection authority of a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679. (...)”,

IX

Sanction for the infringement of Articles 5.1 f), 32, and 33 of the GDPR

Article 83 “General conditions for the imposition of administrative fines” of the GDPR, paragraph 7, establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Furthermore, Article 77 “Regime applicable to certain categories of controllers or processors” of the LOPDGDD provides as follows:

“1. The regime established in this article shall apply to the processing for which the following are controllers or processors: ...

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that make up the Local Administration...

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation

on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for the processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible official and shall order the publication in the corresponding Official State or autonomous Bulletin.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

21/22

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.
(...)"

In view of the above, the following is issued:

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the GENERAL DIRECTORATE OF THE CATASTRO, with NIF S2826053G, a sanction of warning for each of the infringements for a violation of Article 5.1.f) of the GDPR classified in Article 83.5 of the GDPR for a violation of Article 32 of the GDPR and Article 33 of the GDPR classified in Article 83.4 of the GDPR.

SECOND: TO NOTIFY this resolution to the GENERAL DIRECTORATE OF THE CATASTRO.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation evidencing the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension terminated.

938-21112023

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

